

AUDITORÍA CRUZADA

Cómo se audita el contrato de otro equipo: formato de hallazgo, severidades, asignación de equipos, qué se entrega y cómo se califica.

MODALIDAD	MOMENTO 1	MOMENTO 2	SE EVALÚA
Entre equipos de proyecto	Sesión 9 · informe escrito (20 % del corte)	Sesión 17 · una pregunta técnica en vivo	La calidad de la auditoría, no cuántos fallos tenga el otro

POR QUÉ ESTO ES PARTE DEL CURSO

Leer código ajeno con criterio de seguridad es una competencia profesional tan importante como escribirlo. Un auditor no busca lucirse encontrando fallos: busca **reducir el riesgo** de un sistema que custodia valor. Este documento fija las reglas de las dos auditorías cruzadas del semestre para que todos los equipos entreguen con el mismo formato y se califiquen con la misma vara.

01 Los dos momentos de la auditoría

#	CUÁNDO	EN QUÉ CONSISTE
#1	Sesión 9	Informe escrito. Cada equipo audita el contrato principal de otro equipo y entrega un informe de 1 a 2 páginas con hallazgos clasificados. Vale el 20 % del segundo corte, junto con Ethernaut.
#2	Sesión 17 (Demo Day)	Una pregunta técnica en vivo. Durante la sustentación, cada equipo formula al menos una pregunta técnica de seguridad al equipo evaluado. Se califica la calidad de la pregunta (ver sección 6).

Las dos comparten el mismo marco de severidades y el mismo espíritu: mejorar el sistema del otro, no derrotarlo.

02 Cómo se asignan los equipos

- El docente organiza los equipos en un **ciclo**: A audita a B, B audita a C, C audita a D... y el último audita a A. Así nadie audita a quien lo audita (no hay «te perdono si me perdonas»).
- Cada equipo entrega, al inicio del bloque, el **contrato principal** de su proyecto: un solo archivo `.sol` que compile, con sus dependencias declaradas. Nada de capturas: el código real.

3. El equipo auditor recibe **solo el código** y una descripción de una línea de qué hace el contrato. No recibe las pruebas del otro equipo: parte de auditar es entender el contrato sin que te lo expliquen.
4. Media hora de trabajo en clase; el informe puede cerrarse fuera de clase si el tiempo aprieta.

REGLA DE CONDUCTA

Se audita el **código**, no a las personas. No se reescribe el contrato ajeno: se **proponen correcciones mínimas**. Un hallazgo se redacta para que el otro equipo pueda actuar, no para que quede mal.

03 Las cinco severidades

Cada hallazgo se clasifica en una de estas cinco categorías. La severidad combina **impacto** (qué se pierde) y **probabilidad** (qué tan fácil es explotarlo).

SEVERIDAD	CRITERIO	EJEMPLO TÍPICO
Crítica	Pérdida directa de fondos o control del contrato, fácil de explotar por cualquiera.	Reentrancy que vacía el contrato; función de retiro sin control de acceso.
Alta	Pérdida de fondos o de disponibilidad, pero con alguna condición (un rol, un estado, un monto).	<code>tx.origin</code> para autorizar; <code>delegatecall</code> a dirección elegible.
Media	Impacto acotado o que requiere condiciones poco frecuentes; degrada la seguridad sin robo directo.	Aleatoriedad on-chain manipulable; dependencia de <code>block.timestamp</code> .
Baja	Riesgo menor o difícil de explotar; buenas prácticas incumplidas con efecto limitado.	Falta de límite de deslizamiento; envío con retorno no comprobado en caso benigno.
Informativa	No es una vulnerabilidad: es una observación de calidad, gas o legibilidad.	Falta un evento; variable que podría ser <code>immutable</code> ; nombre confuso.

SEÑAL DE MADUREZ: DISTINGUIR HALLAZGO DE RUIDO

Un analizador como Slither marca cosas ciertas que **no** son vulnerabilidades (por ejemplo, «low-level call» en un patrón de retiro correcto). Clasificarlas como **informativas** —y explicar por qué no son explotables— vale tanto como encontrar un fallo real. Inflar la severidad de un hallazgo trivial resta credibilidad al informe.

Todo hallazgo del informe #1 usa exactamente estos seis campos. Un hallazgo sin ubicación o sin recomendación está incompleto.

H

PLANTILLA DE HALLAZGO

Los seis campos

- 1 • **Título:** una línea que nombra el fallo (p. ej. «Reentrancy en `retirar()` »).
- 2 • **Severidad:** Crítica / Alta / Media / Baja / Informativa, según la sección 3.
- 3 • **Ubicación:** archivo, función y **número de línea exacto**.
- 4 • **Descripción:** qué está mal y por qué, en dos o tres frases.
- 5 • **Escenario de explotación:** los pasos concretos por los que un atacante lo aprovecha (o, si es informativo, por qué no es explotable).
- 6 • **Recomendación:** la corrección **mínima**. No reescribir el contrato: señalar el cambio puntual.

EJEMPLO RESUELTO (SOBRE UN CONTRATO DE CLASE)

Título: Reentrancy en la función de retiro.

Severidad: Crítica.

Ubicación: `Banco.sol` · `retirar()` · líneas 21-30.

Descripción: la función envía ETH con `call{value:}` (línea 26) *antes* de poner el saldo en cero (línea 29). El receptor puede reentrar mientras su saldo sigue en pie.

Escenario: un contrato atacante deposita 1, llama `retirar()`, y en su `receive()` vuelve a llamar `retirar()` repetidamente hasta vaciar el contrato.

Recomendación: aplicar Checks-Effects-Interactions (poner `saldos[msg.sender] = 0` antes del `call`) y, como refuerzo, el modificador `nonReentrant` de OpenZeppelin.

05 Qué se entrega y cómo se califica

AUDITORÍA #1 · SESIÓN 9

Entrega: un informe de **1 a 2 páginas** (PDF) con: (a) el contrato auditado y su equipo; (b) el método usado (taxonomía recorrida + Slither); (c) la lista de hallazgos con el formato de la sección 4; (d) un resumen de una línea con la conclusión general.

CRITERIO	PESO	QUÉ SE ESPERA
Cobertura del método	25 %	Se recorrieron las ocho vulnerabilidades de la taxonomía y se corrió Slither, separando señal de ruido.
Hallazgos bien formados	30 %	Cada hallazgo con los seis campos, ubicación exacta y escenario creíble.
Severidad coherente	20 %	La severidad corresponde al impacto real; nada inflado ni minimizado.
Recomendaciones útiles	15 %	Correcciones mínimas y accionables; no se reescribió el contrato ajeno.
Claridad y honestidad	10 %	El informe es legible. «No hallé vulnerabilidades explotables; revisé esto y esto» es una conclusión válida y vale.

LO QUE NO SE PREMIA

No se califica por **cantidad** de hallazgos: un contrato bien hecho puede tener cero vulnerabilidades reales, y decirlo con evidencia es un buen informe. Tampoco se premia el hallazgo espectacular mal ubicado: sin línea y sin escenario, no cuenta.

06 Auditoría #2 · la pregunta técnica (Sesión 17)

MODALIDAD BREVE

En el Demo Day, la auditoría cruzada cambia de forma: en lugar de un informe, cada equipo formula **al menos una pregunta técnica de seguridad** al equipo que sustenta. No es un «gotcha»: es una pregunta que obliga al otro equipo a demostrar que pensó en su seguridad.

UNA BUENA PREGUNTA...	UNA PREGUNTA DÉBIL...
Apunta a un vector concreto de la taxonomía sobre ese contrato: «¿cómo evitan reentrancy en su función de retiro?».	Es genérica o de sí/no: «¿es seguro su contrato?».
Nace de haber leído el código o la arquitectura mostrada.	Se podría hacer sin haber visto nada del proyecto.
Deja al equipo evaluado demostrar criterio, no solo defenderse.	Busca ridiculizar en vez de mejorar.

CÓMO SE CALIFICA LA PREGUNTA

Se evalúa la **pertinencia y profundidad técnica** de la pregunta que formula el equipo auditor: qué tan bien conecta con un riesgo real del proyecto evaluado. Una pregunta que revela lectura del código y dominio de la taxonomía puntúa alto; una genérica, bajo. La respuesta del equipo evaluado se califica aparte, dentro de su propia sustentación.

07 Lista de chequeo del auditor

ANTES DE ENTREGAR EL INFORME #1

OK

Recorrí las ocho vulnerabilidades de la taxonomía, una por una, sobre el contrato recibido.

Corrí Slither y separé los hallazgos reales de los falsos positivos.

Cada hallazgo tiene los seis campos, con línea exacta y escenario.

Las severidades son coherentes con el impacto; no inflé nada.

Cada recomendación es una corrección mínima, no una reescritura.

El informe cabe en 1 o 2 páginas y se entiende sin explicación oral.

La taxonomía de referencia (reentrancy, control de acceso y `tx.origin`, `delegatecall`, desbordamiento, aleatoriedad on-chain, front-running/MEV, oráculos, DoS) y las herramientas (Slither) se estudian en la Sesión 9. Este documento se reutiliza en la Sesión 17 para la modalidad de pregunta técnica.